

Vulnerability	Why Common Sense Fix Fails	ANSS Fix
Confused Deputy	RBAC/IAM only verify Identity . The LLM is the authorized user, so it can be tricked into using its valid keys for a malicious instruction found in a resume or email.	HMAC-Signed Intent: Seals a pre-approved "Intent Graph" at session start. Any tool call that wasn't part of that original cryptographic signature is instantly killed.
Disclosure (LLM06)	Rate limits stop massive scraping, but not "One-Shot Leaks." DLP/Regex fail when the LLM encodes sensitive data into poems, ciphers, or rare languages.	PCTL Verification: Models the output as a Markov Chain. It calculates the probability (\$P\$) of a data leak in real-time. If the math says a leak is likely, the stream terminates.
Context Blindness	Prepared statements secure the <i>database query</i> , but the <i>returned data</i> is read by the LLM as a new command. The "data" becomes "logic."	Semantic Token Tagging: Kernel-level tagging that separates "Data" tokens from "Instruction" tokens. The model's attention is structurally masked to prevent it from executing data.
Insider Threats	Confidential VMs (CVMs) protect against external hackers, but they don't stop an authorized developer from prompting the model to dump its weights.	Dual-LLM Orchestration: Forces all prompts through a constrained "Watcher" model. The Worker LLM is never exposed to raw, unverified prompts, even from admins.